

Kit de Modelos de Políticas GRC

Alberto Al Leiva

1 de agosto de 2026

Table of Contents

Kit de Ferramentas de Modelo de Políticas GRC

Este kit de ferramentas contém modelos educacionais de arranque. Não constitui aconselhamento legal, regulatório, de privacidade, trabalho, contabilidade, certificação ou auditoria formal. Cada modelo deve ser adaptado, revisado, aprovado, implementado e evidenciado para a organização de adoção.

Governança política e hierarquia documental

Objecto

Políticas estabelecem direção de gestão, princípios obrigatórios, responsabilização e limites. Devem ser suficientemente concisas para governar as decisões e estáveis o suficiente para se manterem úteis à medida que a tecnologia e os procedimentos mudam.

Um modelo de política não é uma política adotada. A adoção requer análise específica da organização, propriedade responsável, revisão adequada, aprovação formal, comunicação, implementação e evidência retida.

Hierarquia do documento

Uma hierarquia prática distingue:

- **Política** — orientação obrigatória e princípios aprovados pela gestão autorizada.
- **Padrão** — requisitos obrigatórios e mensuráveis de apoio à política.
- **Procedimento** — passos ordenados para realizar uma atividade.
- **Guideline** — prática recomendada onde a descrição é permitida.
- **Plano** — papéis, ações, recursos e tempo para um cenário definido.
- **** Registro**** — evidência de que ocorreu uma atividade, decisão ou controle.

Não coloque valores de configuração detalhados, contatos em rápida mudança ou instruções passo a passo em uma política de alto nível, a menos que a governança os requeira lá.

Metadados mínimos de política

Cada política controlada deverá identificar:

- Título e identificador único;
- Versão e estatuto;
- O proprietário da apólice;
- Autoridade de aprovação;
- Aprovação e datas de eficácia;
- A data de revisão seguinte;
- Classificação;
- entidades, grupos de trabalhadores, locais, sistemas e dados aplicáveis;
- Normas, procedimentos, planos e registos conexos;
- Autoridade de exceção;
- histórico de revisão.

Funções de governação

Corpo governante ou liderança executiva

Aprova o apetite de risco, a direcção política importante e exceções materiais de acordo com a autoridade delegada.

Titular da política

Mantém conteúdo, coordena revisão, confirma implementação, monitora exceções e inicia revisão.

Controlar e processar proprietários

Aplicar os requisitos, operar os controlos, conservar provas e comunicar o incumprimento ou as barreiras.

Jurídico, privacidade, recursos humanos, conformidade, registos e especialistas em trabalho

Áreas de revisão dentro da sua competência. A sua revisão é necessária quando uma política afecta os direitos jurídicos, o controlo, a privacidade, o emprego, as investigações, a retenção, o processamento transfronteiriço, as convenções colectivas ou a actividade regulamentada.

Auditoria interna ou garantia independente

Pode avaliar a governação e a execução, mas não deve assumir silenciosamente a propriedade da gestão da política.

Princípios de concepção das políticas

Uma política útil é:

- alinhados com objectivos e riscos;

- claro sobre a linguagem obrigatória versus recomendada;
- Mensuráveis sempre que possível;
- realistas para as capacidades da organização;
- Conformidade com outros documentos controlados;
- Tecnologia neutra, se for caso disso;
- explicitar sobre a responsabilidade e as excepções;
- Apoiados por procedimentos, sistemas, formação e registos;
- revisão quando as obrigações ou a alteração do risco.

Língua obrigatória

Utilizar **deve** ou **dever** para requisitos obrigatórios e **dever** para recomendações. Evite expressões vagas como “se necessário”, “regularmente” ou “apropriado”, a menos que critérios ou julgamento delegado sejam definidos.

Âmbito de aplicação

Defina quem e o que a política cobre. Considere funcionários, empreiteiros, trabalhadores temporários, estagiários, voluntários, provedores de serviços, subsidiárias, joint ventures, serviços na nuvem, tecnologia operacional, dispositivos móveis, trabalho remoto e informações em todos os formatos.

Relação com o direito e os contratos

As políticas não devem presumir que a regra de uma jurisdição se aplique universalmente. Registre as entidades legais e jurisdições aplicáveis e exija adendas locais onde o emprego, privacidade, vigilância, notificação de violação, retenção, acessibilidade ou regras do setor diferem.

Conflitos políticos

Estabelecer uma rota de escalada para conflitos entre lei, regulamentação, contrato, política, padrão e restrições operacionais. Não direcione o pessoal a violar uma obrigação de prioridade superior. Registrar a decisão e as medidas compensatórias necessárias.

Adaptação, Aprovação e Publicação de Modelos

Objecto

Um modelo deve ser convertido em um documento controlado específico da organização antes de ser invocado. Os titulares de lugares, cláusulas opcionais, frequências de exemplo e papéis genéricos devem ser resolvidos através de revisão documentada.

Fluxo de trabalho de adaptação

1. Identificar a entidade jurídica, jurisdições, unidades de negócio, sistemas, dados, força de trabalho e terceiros no âmbito.

2. Mapa leis, regulamentos, contratos, normas, compromissos com clientes e decisões internas de risco.
3. Atribuir um proprietário de política responsável e equipe de redação.
4. Resolver cada placeholder e cláusula opcional.
5. Alinhar terminologia com a hierarquia de documentos da organização e modelo operacional.
6. Confirmar que existem ou são financiados procedimentos, tecnologia, pessoal, formação e registos necessários.
7. Realizar revisão legal, privacidade, recursos humanos, registros, conformidade, segurança e acessibilidade conforme aplicável.
8. Resolver conflitos e registrar decisões materiais.
9. Obter a aprovação da autoridade delegada.
10. Publicar através do repositório controlado, comunicar, treinar, implementar e reter provas.

Controlos dos locais

Os modelos usam campos com parênteses como [ORGANIZATION], [POLICY OWNER], [TIME PERIOD] e [APPROVING AUTHORITY]. Uma verificação de liberação deve falhar quando os placeholders não resolvidos permanecer, exceto quando um formulário aprovado intencionalmente pede ao usuário para obter dados.

Cláusulas facultativas

As cláusulas facultativas devem ser seleccionadas com base nos riscos e obrigações, não copiadas automaticamente. Remova instruções e notas de redação da versão aprovada. Registre por que as cláusulas materiais foram incluídas, modificadas ou omitidas.

Elementos de prova de reexame

Manter provas de:

- Revisores e datas;
- Observações e resoluções;
- Suposições legais ou regulamentares;
- Decisões de risco;
- Autoridade de homologação;
- Versão final controlada;
- Comunicação e formação;
- Dependências de execução;
- excepções e adendas locais.

Aprovação

A aprovação confirma a direção de gestão e a responsabilização. Não certifica a conformidade legal nem a eficácia do controlo. O registo de aprovação deverá identificar a versão, a data de eficácia, o prazo de execução e quaisquer condições.

Publicação

Publicar apenas a cópia controlada aprovada. Impedir que rascunhos obsoletos pareçam autoritários. As políticas aprovadas devem ser pesquisáveis, acessíveis ao público pretendido, protegidas contra alterações não autorizadas e disponíveis durante as interrupções quando for necessário.

Comunicação e reconhecimento

Escolha métodos de comunicação proporcionais ao impacto. Políticas de alto impacto podem exigir treinamento baseado em funções, formatos traduzidos ou acessíveis, briefings de gerente e agradecimentos. Um aviso comprova a recepção ou a comprovação, a não compreensão ou o cumprimento.

Adendas locais

Use addendas locais quando as leis, regras trabalhistas, restrições de monitoramento, violações de deveres, requisitos de registros ou condições operacionais variarem. Adenda deve identificar precedência e não deve enfraquecer os requisitos das empresas sem autoridade aprovada.

Emissão de emergência

Uma política de emergência pode utilizar uma revisão acelerada quando o atraso criar riscos materiais. Registre a base, aprovação temporária, período efetivo, comunicação e prazo para revisão completa. O estatuto de emergência não pode ser indefinido.

Implementação, Provas, Formação e Acompanhamento

Objecto

Uma política só é eficaz quando estão em funcionamento controlos, recursos, procedimentos, formação e acompanhamento. A publicação por si só não estabelece a implementação.

Plano de execução

Para cada requisito material, identificar:

- O proprietário responsável;
- Norma ou procedimento de apoio;
- dependência tecnológica ou de processos;
- Orçamento e pessoal necessários;
- Prazo de execução;

- população afectada;
- Formação ou comunicação;
- Fonte de provas;
- Método de monitorização;
- rota de escalada.

Provas de execução

As provas podem incluir normas e procedimentos aprovados, exportações de configuração, registos de acesso, conclusão de formação, registos de revisão, relatórios de incidentes, resultados de testes, registos de fornecedores, aprovações de excepções, relatórios de gestão e acções correctivas.

Os elementos de prova devem ser autênticos, completos, actuais, rastreáveis, devidamente protegidos e conservados de acordo com os requisitos aplicáveis.

Formação

A formação deve ser baseada no papel e cronometrada até à data efectiva da política. Funções especializadas podem exigir exercícios, instrução técnica ou validação de competências. Manter alternativas acessíveis e acomodações razoáveis quando necessário.

Acompanhamento

O controlo deverá determinar se os requisitos são aplicados e funcionam, e não apenas se a política existe. As medidas úteis incluem:

- conclusão da execução;
- Dependências atrasadas;
- volume e idade da excepção;
- violações repetidas;
- Resultados da conclusão e avaliação da formação;
- Falhas de controlo;
- Tendências de incidentes ou perdas;
- Estatuto da acção correctiva;
- questões políticas e indicadores de ambiguidade.

Incumprimento

Defina uma escalada justa e consistente. O incumprimento pode resultar de má conduta, requisitos obscuros, recursos indisponíveis, defeitos do sistema, obrigações conflitantes ou prazos irrealistas. Investigue os fatos e aplique recursos humanos, processos legais, contratuais e disciplinares, conforme aplicável.

Automação e IA

Ferramentas automatizadas podem auxiliar na distribuição, reconhecimento, mapeamento, monitoramento e análise de rascunho. Não devem inventar aprovações, conclusões legais,

evidências de implementação, exceções ou resultados de revisão. A responsabilidade humana permanece com o proprietário designado e o aprovador.

Acessibilidade e linguagem

Fornecer políticas em formatos e idiomas necessários pelo público pretendido. Tradução automatizada é um candidato à publicação, não prova de precisão na língua nativa. Os testes de acessibilidade em aplicações nativas devem ser realizados sempre que necessário.

Melhoria contínua

Use incidentes, resultados de auditoria, feedback do usuário, mudanças legais, falhas de controle, mudanças de tecnologia e mudanças de negócios para melhorar o design de políticas. Preservar o histórico de revisão e evitar alterações silenciosas aos requisitos obrigatórios.

Exceções, Revisão, Registros e Ciclo de Vida

Exceções

Uma exceção é um desvio documentado e aprovado de uma exigência política. Não deve ser utilizado para ocultar o incumprimento ou evitar financiar um controle conhecido indefinidamente.

Um registo de exceção deve identificar:

- Política e requisitos;
- O requerente e a justificação comercial;
- sistemas, pessoas, dados e período afetados;
- Avaliação dos riscos;
- Revisão legal, de privacidade, contratual e operacional;
- Controlos compensadores;
- O proprietário responsável;
- Autoridade de homologação;
- Datas de início e de expiração;
- Monitorização e revisão da frequência;
- plano de reparação ou de saída;
- Condições de revogação.

Autoridade de exceção

A entidade homologadora deve reflectir o risco. Exceções de alto risco podem exigir executivo, comitê de risco, legal, privacidade, cliente, regulador ou envolvimento do corpo governante. O proprietário da apólice não deve aprovar uma exceção fora da autoridade delegada.

Interruptores de revisão

Rever as políticas num ciclo definido e quando desencadeadas por:

- Alterações materiais legais ou regulamentares;
- compromissos contratuais novos ou alterados;
- Incidentes ou falhas de controlo;
- resultados significativos de auditoria;
- fusão, aquisição, alienação ou reestruturação;
- Nova tecnologia, IA, nuvem ou tecnologia operacional;
- Alterações no tratamento ou monitorização de dados;
- força de trabalho ou mudanças de trabalho;
- Alterações significativas no fornecedor;
- repetidas exceções ou ambiguidades.

Revisão periódica

Uma revisão deverá confirmar a necessidade contínua, o âmbito, a propriedade, a coerência, a implementação, as provas, as exceções e o alinhamento com o risco actual. “Revisão sem alterações” ainda requer um registro datado e aprovação responsável de acordo com a governança.

Controle de revisão

Mantenha um histórico de revisão mostrando versão, data, resumo, autor, revisores e aprovador. As alterações materiais devem ser comunicadas e podem exigir reciclagem ou reconhecimento renovado.

Retirada e arquivamento

Quando uma política é substituída ou retirada:

- Identificar o documento sucessor;
- Indicar a data de retirada efectiva;
- remover cópias públicas obsoletas;
- Conservar os registos necessários;
- Atualizar os mapeamentos, procedimentos, formação e contratos;
- comunicar a alteração;
- Manter versões históricas de acordo com os requisitos dos registos.

Registos

Os registros de políticas podem incluir rascunhos, comentários, aprovações, revisão legal, reconhecimentos, treinamento, evidências de implementação, exceções, monitoramento, incidentes, investigações e histórico de revisão. Classificar e proteger esses registros; alguns podem conter informações privilegiadas, pessoais, sensíveis à segurança ou confidenciais.

Métricas e relatórios

Relatar status de política, revisões atrasadas, espaços não resolvidos, lacunas de implementação, exceções, incumprimento recorrente, treinamento e ações corretivas. Evite métricas que recompensam a aprovação rápida, ignorando a qualidade da implementação.

Sequência de uso do kit de ferramentas

1. Leia o manual de implementação.
2. Selecione apenas modelos aplicáveis.
3. resolver todos os espaços e elaborar notas.
4. Realizar revisão jurisdicional e especializada.
5. Aprovar através da governação delegada.
6. Publicar a cópia controlada.
7. Aplicar procedimentos, controles, formação e registos.
8. Monitorar o desempenho e as exceções.
9. Rever, rever ou retirar através da gestão controlada do ciclo de vida.

Modelo de Política de Segurança da Informação

**** Aviso de fuga: **** Resolva todos os campos interligados e obtenha dados legais, privacidade, recursos humanos, conformidade, registros, segurança e revisão de acessibilidade conforme aplicável antes da aprovação.

Controlo dos documentos

- ID da política: [POLICY ID]
- Proprietário: [POLICY OWNER]
- Autoridade de aprovação: [APPROVING AUTHORITY]
- Versão: [VERSION]
- Data de eficácia: [DATE]
- Próxima revisão: [DATE]
- Classificação: [CLASSIFICATION]

1. Objecto

A [ORGANIZATION] estabelece essa política para proteger os objetivos de informação, tecnologia, serviços, pessoas e negócios através de controles de segurança e governança baseados em risco.

2. Âmbito de aplicação

Esta política aplica-se à [LEGAL ENTITIES, WORKFORCE, CONTRACTORS, LOCATIONS, SYSTEMS, DATA, CLOUD SERVICES, AND THIRD PARTIES].

3. Princípios

[ORGANIZATION] deve:

- Gerir o risco de segurança da informação dentro do risco de apetite aprovado;
- Atribuir aos proprietários responsáveis informações, sistemas, serviços e controlos;
- Aplicar segurança ao longo de toda a aquisição, concepção, desenvolvimento, operação, mudança e eliminação;
- Proteger a confidencialidade, integridade, disponibilidade, autenticidade e resiliência em função do risco;
- Cumprir os requisitos legais, regulamentares, contratuais, de privacidade, registros e clientes aplicáveis;
- Manter as capacidades de incidente, continuidade, recuperação, fornecedor, vulnerabilidade, identidade, registo e monitorização;
- Prestar sensibilização e formação baseadas no papel;
- Medir o desempenho do controlo e corrigir deficiências;
- Documento e aprovação de excepções.

4. Governação

[GOVERNING BODY OR EXECUTIVE] aprova direcção de segurança e apetite de risco. [CISO OR SECURITY LEADER] coordena o programa de segurança. Os proprietários de negócios, dados, sistema, processo e controlo permanecem responsáveis por riscos e controlos dentro de sua autoridade.

5. Gestão dos riscos

Os riscos de segurança devem ser identificados, avaliados, tratados, monitorizados e comunicados utilizando [RISK METHODOLOGY]. A aceitação do risco deve ser aprovada pela [AUTHORITY] e revista pela [FREQUENCY].

6. Gestão de activos e informação

Os activos de informação e tecnologia devem ser inventariados, designados proprietários, classificados, manuseados, retidos e eliminados de acordo com os requisitos aprovados.

7. Identidade e acesso

O acesso deve ser autorizado, menos privilegiado, revisto periodicamente, prontamente alterado ou revogado e protegido com controlos de autenticação proporcionais ao risco.

8. Ciclo de vida da tecnologia segura

Os requisitos de segurança devem ser incluídos na arquitetura, aquisição, desenvolvimento, configuração, testes, implantação, mudança, manutenção e desativação.

9. Operações e resiliência

[ORGANIZATION] deve manter o gerenciamento de vulnerabilidade, proteção de malware, backup, recuperação, registro, monitoramento, capacidade, configuração, resposta incidente, continuidade e controles de recuperação de desastres proporcionais ao risco.

10. Terceiros

Os riscos de segurança e privacidade decorrentes de fornecedores e outros terceiros devem ser avaliados, tratados contratualmente, monitorados e geridos através da cessação ou transição.

11. Relatórios

Suspeitos de incidentes de segurança, falhas de controle, violações de políticas e riscos materiais devem ser reportados através do [REPORTING CHANNEL] sem retaliação quando protegidos por lei.

12. Exceções

Exceções exigem justificação documentada, avaliação de risco, controles compensadores, proprietário, data de validade, monitoramento e aprovação pelo [EXCEPTION AUTHORITY].

13. Execução

As violações podem resultar em ações corretivas, contratuais ou disciplinares compatíveis com a legislação, contratos, regras de força de trabalho, processo devido e procedimentos aprovados.

14. Documentos relacionados

[LIST STANDARDS, PROCEDURES, PLANS, AND REGISTERS]

15. Revisão e aprovação

Esta política deve ser revista pelo menos [FREQUENCY] e após alterações materiais. Os registros de aprovação e o historial de revisão devem ser conservados.

Modelo de política de controle de acesso

Resolva todos os placeholders e revise o emprego, privacidade, monitoramento, acesso privilegiado, cliente e requisitos regulatórios antes da aprovação.

Controle dos documentos

- ID da política: [POLICY ID]
- Proprietário: [POLICY OWNER]
- Aprover: [APPROVING AUTHORITY]
- Data de eficácia: [DATE]
- Data de revisão: [DATE]

1. Objecto

Esta política estabelece requisitos para a concessão, utilização, revisão, alteração e revogação do acesso à informação [ORGANIZATION], sistemas, serviços, instalações e funções administrativas.

2. Âmbito de aplicação

Aplica-se à [USERS, WORKFORCE, CONTRACTORS, SERVICE ACCOUNTS, APPLICATIONS, DEVICES, THIRD PARTIES, CLOUD AND ON-PREMISES SYSTEMS].

3. Requisitos

3.1 Identidade

Cada utilizador deve utilizar uma identidade única aprovada, a menos que uma excepção técnica documentada permita uma conta partilhada ou funcional controlada. Os registos de identidade devem ser rastreáveis para um proprietário responsável.

3.2 Autorização

O acesso deve ser aprovado pelo [DATA/SYSTEM/PROCESS OWNER], baseado na necessidade de negócios, menos privilégio, segregação de deveres e definições de papéis aprovados.

3.3 Autenticação

A intensidade da autenticação deve reflectir o risco. A autenticação multifatorial é necessária para [DEFINED SYSTEMS, REMOTE ACCESS, PRIVILEGED ACCESS, AND OTHER USE CASES], sujeita a alternativas aprovadas e acomodações de acessibilidade.

3.4 Acesso privilegiado

O acesso privilegiado deve ser autorizado separadamente, limitado, monitorado, revisto e utilizado apenas para atividades administrativas aprovadas. O acesso de emergência deve estar ligado ao tempo e revisto após a utilização.

3.5 Controles de joiner, mover e leaver

O acesso deve ser fornecido, modificado, suspenso e revogado no [TIMEFRAMES] com base em força de trabalho ou eventos contratuais. Excepções e notificações falhadas devem ser reconciliadas e intensificadas.

3.6 Revisão do acesso

Os proprietários devem revisar o acesso pelo menos [FREQUENCY] e após mudanças materiais, sistema, risco ou organizacionais. As avaliações devem abranger acesso privilegiado, dormente, serviço, terceiros e conflitantes.

3.7 Identidades de serviço e máquina

Contas de serviço, credenciais API, certificados, segredos e identidades de máquinas devem ter proprietários, finalidade documentada, menos privilégio, armazenamento seguro, rotação, monitoramento e controles de aposentadoria.

3.8 Acesso remoto e de terceiros

O acesso remoto e de terceiros deve utilizar métodos aprovados, períodos de tempo definidos, controles de segurança, procedimentos de registro e terminação.

3.9 Registo e monitorização

Autenticação, autorização, atividade privilegiada, mudanças de acesso e falhas significativas devem ser registradas e monitoradas de acordo com a Política de Registro e Monitoramento e as regras de privacidade aplicáveis.

4. Exceções

Exceções exigem risco documentado, compensando controles, proprietário, expiração e aprovação pelo [AUTHORITY].

5. Registos

Reter pedidos, aprovações, registros de provisionamento, revisões, exceções, registros e provas de revogação de acordo com [RETENTION REQUIREMENT].

6. Execução e revisão

As violações são tratadas sob procedimentos aprovados e legislação aplicável. Esta política é revisada pelo menos [FREQUENCY] e após mudança material, tecnologia, legal ou organizacional.

Modelo de Política de Uso Aceitável

Reveja os requisitos de força de trabalho, monitoramento, privacidade, trabalho, acessibilidade, denunciante e lei local antes da adoção.

Controlo dos documentos

- ID da política: [POLICY ID]
- Proprietário: [POLICY OWNER]
- Aprover: [APPROVING AUTHORITY]
- Data de eficácia: [DATE]
- Data de revisão: [DATE]

1. Objecto

Esta política define o uso aceitável e proibido do [ORGANIZATION] informação, tecnologia, comunicações, contas, redes, dispositivos, instalações e serviços.

2. Âmbito de aplicação

Aplica-se à [WORKFORCE, CONTRACTORS, TEMPORARY PERSONNEL, VOLUNTEERS, THIRD PARTIES, DEVICES, NETWORKS, CLOUD SERVICES, AND PERSONALLY OWNED DEVICES WHEN AUTHORIZED].

3. Responsabilidades gerais

Os utilizadores devem:

- Utilizar recursos principalmente para fins autorizados;
- Proteger as credenciais, dispositivos, informações e acesso físico;
- seguir os requisitos de classificação, manipulação, retenção, privacidade e registos;
- Comunicar prontamente perda, suspeita de compromisso, conteúdo proibido, incidentes ou falha de controlo;
- Cumprir licenças, direitos de propriedade intelectual, contratos e lei aplicável;
- Evitar ações que criem riscos de segurança, operacionais, legais ou de reputação excessivos.

4. Actividades proibidas

Salvo autorização expressa para funções legítimas, os utilizadores não devem:

- Acesso, alteração, divulgação, cópia ou destruição de informações sem autorização;
- Ignorar os controlos de segurança, monitorização, acesso ou licenciamento;
- instalar software, serviços, extensões ou dispositivos não aprovados;
- introduzir malware, realizar testes não autorizados ou interferir com os serviços;
- Partilhar credenciais ou utilizar a identidade de outra pessoa;
- Utilizar recursos para assédio, discriminação, retaliação, vigilância ilegal, fraude, roubo ou conteúdo proibido;
- Armazenar informações organizacionais em contas ou serviços pessoais não aprovados;
- Fazer declarações ou compromissos públicos não autorizados em nome da [ORGANIZATION];
- Utilizar IA generativa ou ferramentas externas com informações restritas contrárias aos requisitos aprovados.

5. Uso pessoal limitado

[ORGANIZATION POLICY ON PERSONAL USE]. O uso pessoal não deve interferir com o trabalho, consumir recursos desarrazoados, criar risco, violar lei ou política, ou implicar endosso organizacional.

6. Monitorização e privacidade

O uso pode ser registrado, monitorado, revisto ou divulgado apenas conforme autorizado por lei, política, contratos, anúncios e procedimentos aprovados. Esta cláusula deve ser adaptada às exigências locais de privacidade e trabalho. Não elimina direitos que não possam ser legalmente renunciados.

7. Trabalho remoto e uso móvel

Os usuários devem seguir os requisitos de acesso remoto aprovado, segurança do dispositivo, privacidade física, viagem e manipulação de informações. Perda ou roubo deve ser relatado dentro [TIMEFRAME].

8. IA e automação

Os usuários devem seguir o [AI USE POLICY OR STANDARD], validar saídas, proteger informações confidenciais e pessoais, respeitar a propriedade intelectual e manter a responsabilidade humana pelas decisões.

9. Excepções

Excepções exigem necessidade de negócios documentada, revisão de risco, controles compensadores, duração e aprovação pela [AUTHORITY].

10. Execução e reconhecimento

Violações podem resultar em ação corretiva, disciplinar, contratual ou legal consistente com a lei aplicável e o devido processo. Os registos de reconhecimento devem ser conservados de acordo com o [RETENTION REQUIREMENT].

Modelo da política de resposta de incidentes

**** Aviso de fuga: **** Resolver e adaptar os requisitos legais, regulamentares, contratuais, de privacidade, seguros, aplicação da lei, privilégio e notificação de violação antes da aprovação.

Controlo dos documentos

- ID da política: [POLICY ID]
- Proprietário: [POLICY OWNER]
- Aprover: [APPROVING AUTHORITY]
- Data de eficácia: [DATE]
- Data de revisão: [DATE]

1. Objecto

Esta política estabelece governança para preparar, detectar, relatar, analisar, conter, erradicar, recuperar e aprender com incidentes de cibersegurança, privacidade, tecnologia e informação.

2. Âmbito de aplicação

Aplica-se à [ENTITIES, WORKFORCE, SYSTEMS, DATA, FACILITIES, CLOUD, OPERATIONAL TECHNOLOGY, SUPPLIERS, AND SERVICES].

3. Governação

[INCIDENT RESPONSE LEADER] coordena a resposta. Jurídico, privacidade, comunicações, recursos humanos, continuidade de negócios, tecnologia, segurança, registros, seguros e executivos participam de acordo com o tipo de incidente e gravidade.

4. Relatórios

Os incidentes suspeitos devem ser reportados imediatamente através do [CHANNELS]. O pessoal deve preservar as provas e não deve conduzir investigações, comunicações ou remediações não autorizadas que possam aumentar os danos.

5. Classificação e escalada

Os incidentes devem ser classificados usando [SEVERITY MODEL], considerando segurança, operações, dados, clientes, deveres legais, impacto financeiro, terceiros e interesse público. Os prazos de escalação são [TIMEFRAMES].

6. Requisitos de resposta

A organização deve manter e exercer capacidades para:

- Preparação e gestão de contactos;
- detecção e ingestão;
- Triagem e análise;
- As decisões de contenção e de risco empresarial;
- erradicação e recuperação segura;
- Conservação de provas e cadeia de custódia;
- coordenação legal, privacidade, contratual, seguradora, cliente, regulador e aplicação da lei;
- Comunicações internas e externas;
- revisão pós-incidente e medidas corretivas.

7. Autoridade de decisão

Autoridade para o isolamento do sistema, desligamento do serviço, comunicação pública, decisões relacionadas com resgate, notificação de cliente, notificação de regulador e referência de aplicação da lei devem ser atribuídas em [INCIDENT RESPONSE PLAN].

8. Provas e registos

Registros de incidentes devem ser precisos, cronometrados, controlados pelo acesso e mantidos de acordo com os requisitos legais, privilégios, privacidade, contrato, seguro e registros.

9. Terceiros

Os contratos e procedimentos operacionais devem definir as obrigações de prestação de informações, cooperação, provas, notificação, recuperação e pós-incidente.

10. Exercícios e melhoria

Os planos devem ser testados pelo menos [FREQUENCY] e após a mudança de material. Lições e ações corretivas devem ser atribuídas, rastreadas, validadas e relatadas.

11. Excepções

Excepções exigem risco documentado, duração, controles compensadores e aprovação por [AUTHORITY].

Modelo de política de continuidade de negócios e recuperação de desastres

Adapte os requisitos de segurança, gestão de emergência, regulamentação, contratual, seguro, trabalho, acessibilidade e resiliência local antes da aprovação.

Controlo dos documentos

- ID da política: [POLICY ID]
- Proprietário: [POLICY OWNER]
- Aprover: [APPROVING AUTHORITY]
- Data de eficácia: [DATE]
- Data de revisão: [DATE]

1. Objecto

Esta política estabelece requisitos para proteger as pessoas, manter ou restaurar produtos e serviços priorizados, recuperar tecnologia e informação e coordenar a resposta a eventos disruptivos.

2. Âmbito de aplicação

Aplica-se à [ENTITIES, LOCATIONS, BUSINESS SERVICES, TECHNOLOGY, INFORMATION, WORKFORCE, FACILITIES, SUPPLIERS, AND DEPENDENCIES].

3. Governação

[EXECUTIVE SPONSOR] fornece supervisão. [CONTINUITY OWNER] mantém o programa. Os proprietários de serviços de negócios identificam prioridades e dependências. Os proprietários de tecnologia mantêm as capacidades de recuperação alinhadas aos objetivos aprovados.

4. Análise de impacto empresarial

Atividades priorizadas devem ter documentado análise de impacto cobrindo segurança, cliente, legal, operacional, financeiro, dados, fornecedor e consequências de reputação ao longo do tempo.

5. Objectivos de recuperação

A gestão deve aprovar objetivos de tempo de recuperação, objetivos de ponto de recuperação, níveis mínimos de serviço, ruptura tolerável máxima e pressupostos de dependência para [DEFINED SERVICES].

6. Planos

A organização deve manter planos acessíveis e controlados para a gestão de crises, continuidade de negócios, recuperação de desastres tecnológicos, comunicações, continuidade de mão-de-obra, instalações e rompimento do fornecedor conforme aplicável.

7. Backup e recuperação

Os backups devem ser protegidos, monitorados, testados, retidos e separados de acordo com o risco. Os procedimentos de recuperação devem abordar integridade, autorização, priorização, dependências e retorno seguro às operações normais.

8. Resiliência de terceiros

Os fornecedores e serviços críticos devem ser avaliados quanto à capacidade de continuidade, concentração, geográfica, tecnologia, risco financeiro e de transição. Os contratos deverão definir as obrigações de continuidade, ensaio, notificação, recuperação e saída.

9. Exercícios e validação

Os planos e capacidades de recuperação devem ser exercidos pelo menos [FREQUENCY] e após alterações de material. Os testes devem ter objetivos, cenários, participantes, resultados, exceções e ações corretivas. Uma mesa de sucesso não prova recuperação técnica.

10. Ativação e comunicação

A autoridade de ativação, o comando incidente, a comunicação dos funcionários, a comunicação dos clientes e reguladores e as decisões de retorno ao normal devem ser definidas em planos aprovados.

11. Registos e melhoria

Manter análises de impacto, planos, aprovações, testes, evidências de recuperação, incidentes, comunicações e ações corretivas de acordo com [RETENTION REQUIREMENT].

12. Exceções

Exceções exigem risco documentado, medidas provisórias, proprietário, expiração e aprovação pela [AUTHORITY].

Modelo de política de risco para terceiros e fornecedores

Adaptar contratos, concorrência, terceirização, privacidade, setor, sanções, registros, requisitos trabalhistas, financeiros e contratuais antes da aprovação.

Controlo dos documentos

- ID da política: [POLICY ID]
- Proprietário: [POLICY OWNER]
- Aprover: [APPROVING AUTHORITY]
- Data de eficácia: [DATE]
- Data de revisão: [DATE]

1. Objecto

Esta política estabelece requisitos para identificar, avaliar, aprovar, contratar, monitorar, mudar e terminar relações de terceiros e riscos associados à cadeia de suprimentos.

2. Âmbito de aplicação

Aplica-se à [SUPPLIERS, CONTRACTORS, CONSULTANTS, CLOUD PROVIDERS, PROCESSORS, SUBPROCESSORS, OUTSOURCERS, PARTNERS, SOFTWARE, HARDWARE, DATA, AND OTHER THIRD PARTIES].

3. Inventário e propriedade

Todas as relações in-scope devem ser gravadas em [AUTHORITATIVE REGISTER] com um proprietário de empresa, descrição de serviço, dados e acesso ao sistema, criticidade, locais, subprocessadores, datas de contrato e dependências de saída.

4. Classificação de risco

Os terceiros devem ser discriminados antes do compromisso, utilizando critérios como criticidade do serviço, sensibilidade à informação, acesso privilegiado, dependência operacional, concentração, exposição financeira, geografia, relevância regulamentar, recuperabilidade e substituíbilidade.

5. Due diligence

A devida diligência deve ser proporcional ao risco e pode abranger segurança, privacidade, resiliência, legal, conformidade, financeira, sanções, seguros, ética, acessibilidade, força de trabalho e dependências de terceiros. As limitações de evidência e os achados não resolvidos devem ser documentados.

6. Aprovação e decisões de risco

O proprietário do negócio, aquisição, legal, privacidade, segurança, conformidade e outras funções necessárias devem aprovar de acordo com [AUTHORITY MATRIX]. Riscos residuais e exceções exigem aceitação responsável.

7. Requisitos contratuais

Os contratos deverão satisfazer os requisitos aplicáveis em matéria de segurança, privacidade, confidencialidade, restrições de utilização, auditoria e garantia, notificação de incidentes, cooperação, continuidade comercial, subcontratantes, localização, devolução ou supressão de dados, registos, seguro, responsabilidade, rescisão e transição.

8. Controlo em curso

A frequência e a profundidade de monitorização devem reflectir o risco. Revisões de gatilho incluem incidentes, falhas de controle, mudanças materiais, aquisições, deterioração financeira, novos subprocessadores, mudanças de localização, ação regulatória e falhas de serviço repetidas.

9. Acesso e dados

O acesso de terceiros e o processamento de dados devem ser autorizados, menos privilegiados, dentro do tempo, sempre que possível, registrados, revisados e revogados na terminação. Os dados devem ser devolvidos, transferidos, retidos ou excluídos de forma segura de acordo com os requisitos aprovados.

10. Resiliência e saída

As relações críticas devem ter planos de continuidade, recuperação, transição e saída. Deve considerar-se a concentração, o bloqueio, a transferência de conhecimentos, a portabilidade dos dados e o tempo de condução de substituição.

11. Registos

Reter avaliações, aprovações, contratos, evidências, descobertas, monitoramento, incidentes, exceções, rescisão e confirmação de devolução de acordo com [RETENTION REQUIREMENT].

12. Excepções

Excepções exigem justificação documentada, risco, controles compensadores, proprietário, duração, monitoramento e aprovação pelo [AUTHORITY].

Modelo de Política de Proteção de Dados e Privacidade

Este modelo requer privacidade e revisão legal qualificadas específicas da jurisdição. Não assumir uma lei de privacidade, base jurídica, período de retenção, regra de acompanhamento dos empregados ou mecanismo transfronteiriço aplica-se universalmente.

Controlo dos documentos

- ID da política: [POLICY ID]
- Proprietário: [PRIVACY OR POLICY OWNER]
- Aprover: [APPROVING AUTHORITY]
- Data de eficácia: [DATE]
- Data de revisão: [DATE]

1. Objecto

Esta política estabelece princípios e governança para o processamento legal, justo, transparente, seguro e responsável de informações pessoais pela [ORGANIZATION].

2. Âmbito de aplicação

Aplica-se à [LEGAL ENTITIES, WORKFORCE, CUSTOMERS, USERS, APPLICANTS, CHILDREN OR VULNERABLE PEOPLE IF APPLICABLE, THIRD PARTIES, SYSTEMS, LOCATIONS, AND PROCESSING ACTIVITIES].

3. Princípios

As informações pessoais devem ser:

- Transferidos sob uma autoridade legal identificada ou para fins autorizados;
- Recolhidos para fins específicos e não incompatíveis;
- Limitados ao necessário;
- Precisão e correcção, quando necessário;
- Retido apenas como autorizado;
- Protegidos de acordo com o risco;
- Processados de forma transparente e com governação responsável;
- Manuseados de forma a apoiar os direitos e as soluções aplicáveis.

4. Registos de transformação

As atividades de processamento in-scope devem ser registradas em [PRIVACY INVENTORY OR RECORD], incluindo finalidade, categorias, indivíduos, sistemas, destinatários, locais, base jurídica, retenção, segurança, transferências e proprietário.

5. Privacidade por projeto

Projetos, produtos, compras, análises, IA, monitoramento e mudanças materiais devem incluir revisão de privacidade o suficiente para influenciar decisões. O processamento de alto risco requer [IMPACT ASSESSMENT PROCESS].

6. Avisos, escolhas e consentimento

Avisos e escolhas devem ser claros, acessíveis, precisos e fornecidos quando necessário. O consentimento só deve ser utilizado quando válido e gerido de acordo com os requisitos aplicáveis; não deve ser apresentado como base universal para o tratamento.

7. Direitos individuais

Os pedidos de acesso, correção, supressão, objeção, restrição, portabilidade, retirada, recurso ou outros direitos aplicáveis devem ser autenticados, registrados, avaliados, cumpridos ou legalmente negados dentro do [TIMEFRAMES].

8. Partilha e terceiros

As informações pessoais só podem ser partilhadas para fins autorizados com contratos adequados, diligência devida, controlos de acesso, mecanismos de transferência e supervisão contínua.

9. Processamento internacional e transfronteiriço

O tratamento transfronteiriço deve ser avaliado e apoiado por mecanismos válidos para as jurisdições aplicáveis. As localizações e as transferências subsequentes devem ser documentadas.

10. Retenção e eliminação

A retenção deve seguir horários aprovados, porções legais, deveres contratuais e necessidades de negócios documentadas. A eliminação deve ser segura e verificável.

11. Segurança e incidentes

As informações pessoais devem ser protegidas por salvaguardas baseadas no risco. Os incidentes suspeitos de privacidade devem ser reportados através do [CHANNEL] e geridos no âmbito da Política de Resposta a Incidentes, incluindo análise de notificação.

12. Força de trabalho e acompanhamento

O processamento de funcionários, empreiteiros e locais de trabalho requer uma revisão jurídica, laboral, de aviso, proporcionalidade e de acesso específica. Esta secção deve ser adaptada localmente.

13. Responsabilidade

[PRIVACY OFFICER OR RESPONSIBLE ROLE] supervisiona o programa. Os proprietários de empresas e sistemas permanecem responsáveis por suas atividades de processamento, registros, controles e ações corretivas.

14. Exceções e execução

Exceções exigem revisão legal e de privacidade, risco documentado, duração, controles e aprovação pela [AUTHORITY]. As violações são tratadas segundo procedimentos e leis aplicáveis.

Gestão de Alterações Modelo de Política

Adaptar segurança, sistema regulamentado, desenvolvimento de software, tecnologia operacional, segregação de tarefas, mudança de emergência, registros e requisitos do cliente antes da aprovação.

Controlo dos documentos

- ID da política: [POLICY ID]
- Proprietário: [POLICY OWNER]
- Aprover: [APPROVING AUTHORITY]
- Data de eficácia: [DATE]
- Data de revisão: [DATE]

1. Objecto

Esta política estabelece requisitos para planejamento, avaliação, autorização, testagem, implementação, documentação, revisão e inversão de alterações na tecnologia [ORGANIZATION], informação, serviços, instalações, configurações e processos controlados.

2. Âmbito de aplicação

Aplica-se à [APPLICATIONS, INFRASTRUCTURE, CLOUD, NETWORKS, SECURITY CONTROLS, DATA, OPERATIONAL TECHNOLOGY, FACILITIES, VENDORS, AND CONTROLLED BUSINESS PROCESSES].

3. Alterar categorias

As alterações devem ser classificadas como [STANDARD, NORMAL, EMERGENCY, MAJOR, OR OTHER APPROVED CATEGORIES] usando critérios documentados. A classificação não deve ser manipulada para evitar a revisão.

4. Mudar o registro

Cada alteração não isenta deve registrar:

- Requerente, proprietário e executor;

- Objetivo comercial e serviços afetados;
- Âmbito, dependências e calendário;
- segurança, privacidade, resiliência, dados, cliente e impacto regulamentar;
- Critérios de ensaio e de aceitação;
- Plano de execução e de retrocesso;
- aprovações;
- Comunicações;
- resultado, exceções e revisão pós-implementação.

5. Avaliação e aprovação dos riscos

A autoridade competente para proceder à análise da profundidade e aprovação deve reflectir o risco, a criticidade, a segregação das funções e o potencial impacto. Os revisores necessários podem incluir funções de negócios, tecnologia, segurança, privacidade, continuidade, arquitetura, dados, fornecedor, legal e conformidade.

6. Teste

As alterações devem ser testadas num ambiente adequado antes da produção, a menos que se aplique um processo de emergência aprovado. Os dados de ensaio devem ser autorizados e protegidos. Os resultados e as limitações não resolvidas devem ser documentados.

7. Segregação de direitos

As responsabilidades em matéria de desenvolvimento, aprovação e implementação da produção devem ser separadas sempre que possível e proporcionais ao risco. Os conflitos requerem monitorização e aprovação.

8. Alterações de emergência

As alterações de emergência só podem utilizar a aprovação acelerada para fazer face às necessidades urgentes de risco ou de serviço. Devem ser documentados, autorizados pelo [EMERGENCY AUTHORITY], monitorados e revistos retrospectivamente dentro do [TIMEFRAME].

9. Alterações- padrão

As alterações padrão pré-autorizadas devem ser de baixo risco, repetíveis, documentadas, testadas, monitoradas e periodicamente revisadas. As condições falhadas ou alteradas requerem reclassificação.

10. Revisão pós-implementação

Mudanças importantes, falhadas, de emergência, sensíveis à segurança ou de alto risco requerem revisão de resultados, incidentes, retrocesso, impacto de controle, documentação e lições.

11. Alterações não autorizadas

Alterações não autorizadas ou não documentadas devem ser investigadas, contidas, se necessário, relatadas e abordadas por meio de ações corretivas.

12. Registros, métricas e exceções

Manter registros de mudança de acordo com [RETENTION REQUIREMENT]. Monitorar as alterações falhadas, alterações de emergência, alterações não autorizadas, retrocesso, incidentes e revisões atrasadas. Exceções requerem risco documentado, controles, duração e aprovação por [AUTHORITY].

Modelo de Política de Vulnerabilidade e Gestão de Patch

Adaptar os requisitos de segurança do produto, médico, industrial, tecnologia operacional, nuvem, fornecedor, contratual, fim de vida e regulamentação antes da aprovação.

Controlo dos documentos

- ID da política: [POLICY ID]
- Proprietário: [POLICY OWNER]
- Aprover: [APPROVING AUTHORITY]
- Data de eficácia: [DATE]
- Data de revisão: [DATE]

1. Objecto

Esta política estabelece requisitos para identificar, avaliar, priorizar, tratar, validar e reportar vulnerabilidades e atualizações de segurança que afetam ativos e serviços [ORGANIZATION].

2. Âmbito de aplicação

Aplica-se à [HARDWARE, SOFTWARE, FIRMWARE, CLOUD, APPLICATIONS, NETWORKS, ENDPOINTS, CONTAINERS, OPERATIONAL TECHNOLOGY, MOBILE, THIRD-PARTY SERVICES, AND INTERNET-FACING ASSETS].

3. Pré-requisitos de activos e de propriedade

Os ativos in-scope devem ser inventariados com proprietário, criticidade, exposição, tecnologia, status de suporte e serviço de negócios. Os activos desconhecidos e as lacunas de propriedade devem ser comunicados e tratados.

4. Identificação da vulnerabilidade

[ORGANIZATION] deve usar fontes e métodos aprovados, como digitalização autenticada, testes de aplicativos, avaliação em nuvem, notificações de fornecedores, inteligência de ameaça, revisão de configuração, teste de penetração, análise de código e divulgação coordenada.

Os ensaios devem ser autorizados, planeados com segurança e adequados ao ambiente.

5. Priorização

A prioridade do tratamento deve considerar mais do que uma pontuação técnica. Os critérios incluem evidência de exploração, exposição, criticidade de ativos, dados, privilégio, caminho de ataque, controles compensadores, impacto empresarial, segurança, recuperabilidade e orientação do fornecedor.

6. Prazos de tratamento

As metas de tratamento aprovadas são [DEFINE BY SEVERITY AND CONTEXT]. Os prazos começam no [DEFINED EVENT] e podem ser abreviados para exploração ativa, exposição à internet, serviços críticos ou deveres regulamentares.

7. Opções de tratamento

O tratamento pode incluir patching, mudança de configuração, atualização, remoção, isolamento, controle compensador, restrição de serviço, aceitação de risco ou substituição. As decisões devem abordar a exposição à raiz e ser documentadas.

8. Ensaio e implantação

As actualizações devem ser testadas proporcionalmente ao risco e utilizadas através da gestão aprovada das alterações. O tratamento de emergência pode utilizar procedimentos acelerados. O retorno, backup, compatibilidade e continuidade do serviço devem ser considerados.

9. Excepções e aceitação do risco

Alvos de tratamento perdidos requerem risco documentado, justificação empresarial e técnica, controles provisórios, proprietário, expiração, monitoramento e aprovação pela [AUTHORITY]. Extensões repetidas requerem escalada.

10. Validação

O encerramento requer evidência de que a vulnerabilidade é remediada ou tratada de outra forma. Reescanning, verificação de configuração, confirmação de versão, ou validação equivalente deve ser independente de asserção do proprietário não suportado.

11. Fornecedores e tecnologia não suportada

Vulnerabilidades gerenciadas pelo fornecedor, ativos de fim de vida e patches não disponíveis requerem coordenação documentada, ação contratual, controles compensadores, migração e escalada.

12. Divulgação e comunicação de informações

Relatórios externos de vulnerabilidade devem seguir o [DISCLOSURE PROCESS]. As métricas internas devem abranger cobertura, idade, exposição atrasada, exploração ativa, exceções, recorrência, ativos não suportados e falhas de validação.

13. Registos e revisão

Mantenha inventários, resultados de varredura, tickets, aprovações, exceções, validação, correspondência de fornecedores e métricas de acordo com [RETENTION REQUIREMENT].

Modelo de política de registro e monitoramento

Adaptar a privacidade, o monitoramento da força de trabalho, o sigilo das comunicações, o privilégio, os registros, a investigação, o setor e os requisitos transfronteiriços antes da aprovação.

Controlo dos documentos

- ID da política: [POLICY ID]
- Proprietário: [POLICY OWNER]
- Aprover: [APPROVING AUTHORITY]
- Data de eficácia: [DATE]
- Data de revisão: [DATE]

1. Objecto

Esta política estabelece requisitos para gerar, coletar, proteger, reter, revisar e usar registros e monitorar informações para apoiar segurança, privacidade, operações, resiliência, investigações, conformidade e responsabilização.

2. Âmbito de aplicação

Aplica-se à [APPLICATIONS, CLOUD, NETWORKS, ENDPOINTS, IDENTITY, DATABASES, SECURITY TOOLS, OPERATIONAL TECHNOLOGY, FACILITIES, THIRD PARTIES, AND BUSINESS-CRITICAL SERVICES].

3. Requisitos de registo

Os proprietários devem definir eventos exigidos com base em risco e obrigações. Os eventos relevantes podem incluir:

- Decisões de autenticação e acesso;
- Atividade privilegiada e administrativa;
- Alterações da conta e da permissão;
- Alterações no controlo da segurança;
- Alterações de configuração e implantação;
- Acesso aos dados, exportação, supressão e tratamento de alto risco;
- Falhas de sistema, aplicação, rede e serviço;
- detecção de malware, vulnerabilidade e ameaças;
- ações de resposta a incidentes;
- eventos de apoio, recuperação e continuidade;
- Acesso de terceiros e eventos significativos de fornecedores.

4. Qualidade do registo

Os logs devem ter sincronização de tempo suficiente, identidade de origem, detalhe do evento, integridade e contexto para suportar seu uso pretendido. Dados sensíveis, credenciais, segredos e informações pessoais desnecessárias não devem ser registrados a menos que especificamente autorizados e protegidos.

5. Recolha e disponibilidade

Os registos críticos devem ser transmitidos ou protegidos para reduzir alterações ou perdas não autorizadas. Os sistemas de monitorização devem ter capacidade, disponibilidade, controlo de acesso, apoio e monitorização da saúde proporcionais ao risco.

6. Retenção

Períodos de retenção devem ser definidos pelo [RETENTION SCHEDULE], considerando investigação, operações, contratos, privacidade, porções legais e deveres regulatórios. A retenção mais longa não é automaticamente mais segura e deve ter objetivos documentados.

7. Acesso e confidencialidade

O acesso a logs e ferramentas de monitoramento deve ser menos privilegiado, aprovado, registrado e revisto periodicamente. A investigação e o acesso de monitoramento de funcionários requerem o controle legal, de privacidade, de recursos humanos e trabalhistas.

8. Acompanhamento e resposta

Casos de uso, limiares de alerta, propriedade, severidade, escalada, tempo de resposta e requisitos de evidência devem ser documentados. As indicações devem ser testadas e ajustadas sem suprimir o risco material.

9. Terceiros

Contratos e integrações devem abordar disponibilidade de log, notificação, acesso, retenção, sincronização de tempo, suporte à investigação e transferência segura, quando aplicável.

10. Privacidade e proporcionalidade

O acompanhamento deve ter uma finalidade documentada, autoridade legal, âmbito proporcional, aviso quando necessário, restrições de acesso, limites de retenção e revisão. Esta política não autoriza a vigilância ilegal ou indiscriminada.

11. Validação e métricas

Validar a cobertura da fonte, ingestão, análise, precisão de tempo, operação de alerta, retenção, busca, controle de acesso e resposta. Metrics deve cobrir lacunas de cobertura, falhas de fonte, backlog alerta, falsos positivos, tempos de resposta e eventos de alto risco não revistos.

12. Exceções e registros

Exceções exigem risco documentado, compensando controles, proprietário, duração, monitoramento e aprovação pela [AUTHORITY]. Manter a configuração, casos de uso, revisões de acesso, testes, alertas, investigações, exceções e ações corretivas de acordo com os requisitos aprovados.